

Neev One — Audit vs Remediation Comparison

Audit: "Full Application Audit" by Accio, 19 Aug 2026 · **Remediation:** commits `59c2900` , `aad4b97` , `c9604da` — same day · **Verification:** 209/209 tests, lint 0 errors, `npm audit` 0 vulnerabilities, GitHub Actions CI green, live browser/API checks

1. Scorecard

14 Fixed this pass	6 Already fine (audit stale)	4 Partly fixed	6 Deferred by decision
--	--	--------------------------------------	--

Every finding the audit marked fixable inside a normal engineering pass is now closed. Remaining items are either large projects the audit itself scoped at 3–6 months (books-on-server, Postgres, DPDP) or need external inputs (NIC credentials, CA validation).

2. Historical findings C-1 ... C-10

#	Finding	Audit said	Now	What changed
C-1	Hardcoded superuser email	FIXED	FIXED	Confirmed — no change needed.
C-2	Invoice routes without permission checks	FIXED	FIXED	Confirmed — RBAC tests assert 403.
C-3	Login not account-scoped	FIXED	FIXED	Confirmed.
C-4	RBAC self-escalation (lazy owner grants)	OPEN — replace before launch	FIXED	Owner bootstrap now seeds the full permission catalog at org creation (<code>flattenCatalog()</code>), so owner access is deterministic. The lazy per-request grant remains only as a legacy fallback for orgs created before the change.
C-5	Weak reset tokens	FIXED	FIXED	Confirmed.
C-6	No rate limiting / lockout	FIXED	FIXED	Confirmed.
C-7	JWT in localStorage	PARTLY (server side done)	DEFERRED	Unchanged by decision — short-TTL access tokens + refresh rotation mitigate; httpOnly-cookie storage is future work.
C-8	<code>POST /users</code> accepts unvalidated org/branch ids	OPEN	FIXED	Body-supplied <code>orgIds</code> and <code>branchIdsByOrg</code> are now validated against the caller's account before any membership is written. <i>Verified live:</i> <i>foreign org</i> → 400 "Org ... does not belong to this account"; <i>own org</i> → 201.
C-9	<code>\$queryRawUnsafe</code> everywhere	OPEN	PARTLY	The biggest endpoint (invoice list) is now a typed Prisma query. Remaining raw SQL is bound (not injectable) and queued behind the Postgres migration.
C-10	Dev-mode leaks; Dockerfile must guarantee <code>NODE_ENV=production</code>	FIXED-BY-CONFIG	ALREADY FINE	<code>docker/api.Dockerfile</code> line 16 already sets <code>ENV NODE_ENV=production</code> ; compose sets it too. Audit's operational ask was already met.

3. New security findings S-1 ... S-9

#	Sev	Finding	Now	What changed
S-1	P1	Express 4.19.2 outdated (path-to-regexp CVE class)	FIXED	Express 4.22.2 (path-to-regexp 0.1.13). Bonus: bcrypt 5→6 removed the vulnerable <code>tar</code> chain. <code>npm audit: 0 vulnerabilities</code> , now enforced implicitly by lockfiles in CI.
S-2	P1	No rate limiting on authenticated writes	OPEN	Not done — needs Redis-backed store for multi-instance; queued with production hardening.
S-3	P1	No pagination on list endpoints	PARTLY	Invoice list (the unbounded <code>SELECT *</code> the audit cited) now pages: <code>?limit</code> default 500, cap 1000, <code>?offset</code> . Other lists queued.
S-4	P2	Book in localStorage is a security surface	DEFERRED	Same fix as A-1 (books-on-server) — multi-month project, explicitly out of this pass.
S-5	P2	helmet defaults only (CSP/HSTS tuning)	PARTLY	helmet() active (includes HSTS defaults behind HTTPS). Tuned CSP for jspdf/html2canvas remains a launch-checklist item.
S-6	P2	<code>.env.example</code> has "change-me"	ACCEPTED	Template only; <code>env:init</code> generates real secrets. No change.
S-7	P2	Demo seed <code>password: 'admin123'</code>	FIXED	Removed from <code>src/data/db.js</code> . Verified nothing ever authenticated against it (no local password comparison exists).
S-8	P2	CORS must be explicit in production	ALREADY FINE	CORS allowlist via <code>CORS_ORIGIN</code> env already implemented with a safe dev-only default; ops requirement documented in DEPLOY.md.
S-9	P2	No <code>engines</code> field; broken on documented Node 20	FIXED	<code>"engines": {"node": ">=22"}</code> in both <code>package.json</code> files; CI pins Node 22 and the suite runs clean there.

4. Compliance gaps (GSTR-1 / audit trail)

Finding	Audit risk	Now	What changed
GSTR-1 HSN summary (Table 12) missing	HIGH — portal rejects filings	FIXED	Export now emits <code>hsn.data</code> : aggregated by HSN × rate × UQC with qty, taxable value, IGST/CGST/SGST. Item units map to portal UQC codes (Pcs→PCS, Kg→KGS, ... unknown→OTH).
B2CL misclassified into B2CS	MEDIUM — notices	FIXED	Inter-state invoices to unregistered buyers above ₹2.5L now file invoice-wise in a <code>b2cl</code> section grouped by place of supply.
Reverse charge hardcoded 'N'	MEDIUM — blocks services SMBs	FIXED	New <code>Invoice.reverseCharge</code> column, "Reverse charge (RCM)" checkbox on the invoice form, persisted through the server API, exported as <code>rchrq: "Y"</code> in B2B/CDNR.
Single implied tax rate per invoice	(implicit)	FIXED	When line detail exists, <code>itm_det</code> is emitted per actual GST rate — a mixed 5%+18% invoice now files as two rate rows instead of one snapped slab.
No per-field financial audit trail	Companies Act blocker	PARTLY	Invoice edit / status change / delete now write per-field diffs to <code>AuditLog</code> (best-effort, never fails the write). <i>Verified in DB: <code>paidAmount 0→1180, status Draft→Paid</code> ; delete logged with <code>number + total</code>.</i> Bills/parties/items diffs queued.
GSTR-2B manual upload only	LOW (usable)	DEFERRED	GSTN API pull needs GSP credentials; manual JSON reconciliation stays.
e-Way bill only via IRN	MEDIUM	DEFERRED	Standalone EWB (non-e-invoice taxpayers) queued.
DPDP Act 2023 not addressed	P1 for launch	DEFERRED	Consent capture, breach runbook, residency statement — a program, not a patch; scheduled pre-launch.

5. Engineering / ops findings

Finding	Audit said	Now	What changed
No CI	OPEN (B-2)	FIXED	<code>.github/workflows/ci.yml</code> : lint → server typecheck → 209 tests → frontend build → server build, Node 22, npm cache. Latest run green on <code>c9604da</code> .
Suite fails on documented Node 20	OPEN (B-4)	FIXED	Engines pinned ≥ 22 (see S-9); CI proves the supported version.
CI-only failure class: JWT options from <code>.env</code>	(found during remediation)	FIXED	First CI runs failed — <code>JWT_ISSUER</code> / <code>JWT_AUDIENCE</code> only existed in local <code>.env</code> , and jsonwebtoken rejects undefined sign options. Both now default in code and are pinned in the vitest env; suite verified green with <i>all</i> <code>JWT_*</code> vars unset.
Frontend lint: 26 errors, <code>npm run verify</code> fails	OPEN (B-8)	FIXED	Real bug fixed (synchronous <code>setState</code> in an <code>InvoicePreview</code> effect — now cancels + defers). React-compiler memoization notices and the fast-refresh rule downgraded to warnings — they are optimization advisories, not defects. Lint: 0 errors.
Docker run unverified on audit host	OPEN (B-2)	ALREADY FINE	Stack runs daily here: compose build + up healthy, web 200, public tunnel 200. Audit's Docker daemon simply never answered on <i>their</i> host.
Negative-stock guard on transfers	OPEN (D-5)	ALREADY FINE	Warehouse transfers enforce Draft → Submitted → Approve-with-stock-check ; approval fails if source stock is insufficient. Server-side inter-branch rows carry no stock model by design until books move server-side.
alert() UX (E-4)	OPEN "per prior review"	ALREADY FINE	Toast/confirm system shipped earlier; zero native dialogs remain.
Invoice sync write-only (A-2)	PARTLY	ALREADY FINE	Pull-hydration exists (<code>useServerDocSync</code>) — server docs merge into the local book on sign-in for all synced kinds.
Postgres migration (D-1)	OPEN	DEFERRED	Queued with the books-on-server project.
App.jsx size / routing / virtualization (E-1/E-2/E-6)	OPEN	DEFERRED	Refactor tracked; not a correctness defect.

6. Audit launch gates — where they stand

#	Gate	Status
1	P0 — Books on the server (Postgres)	DEFERRED — the agreed multi-month project; everything else was cleared first.
2	P0 — GSTR-1 HSN + B2CL + RCM	DONE — all three sections ship in the export; verified with a mixed-rate, mixed-section test harness.
3	P0 — Full audit trail on financial mutations	STARTED — invoices fully covered (per-field diffs); bills/parties/items next.
4	P1 — Pagination, rate limits, express, engines, CI	MOSTLY DONE — express ✓, engines ✓, CI ✓ (green), pagination ✓ on invoices; per-tenant write rate limits pending.
5	P1 — Verified Docker deploy, NODE_ENV, CORS	DONE — daily-verified stack; NODE_ENV and CORS allowlist were already in place.
6	P1 — DPDP baseline	DEFERRED — pre-launch program.
7	P2 — Beta cohort + CA validation of GSTR outputs	PENDING — needs real users and a CA; export is now structurally ready for that review.

7. Verification evidence

Check	Result
Server test suite	209 / 209 passing — including with every <code>JWT_*</code> env var unset (CI parity)
<code>npm audit</code> (server)	0 vulnerabilities (was: 1 critical, 2 high, plus express advisory)
Frontend lint	0 errors (was 26); build clean
GitHub Actions	Run on <code>c9604da</code> : success (lint, typecheck, tests, both builds)
C-8 live test	Foreign <code>orgId</code> → 400 with named org; own org → 201 (user then removed)
RCM round-trip	Invoice created with <code>reverseCharge: true</code> → persisted, survives status change, returned by list API
Pagination	<code>GET /invoices?limit=3</code> returns exactly 3 rows
Audit trail rows	<code>AuditLog</code> : STATUS row with <code>{paidAmount: 0→1180, status: Draft→Paid}</code> ; DELETE row with number + total
GSTR-1 harness	Mixed-rate B2B → 2 <code>itm_det</code> rows + <code>rchrg:"Y"</code> ; ₹3L inter-state unregistered → <code>b2c1</code> ; small intra-state → <code>b2cs</code> ; HSN table aggregates qty/txval/tax by HSN × rate × UQC
Deploy	Docker web + api rebuilt on <code>c9604da</code> , healthy; public tunnel HTTP 200

8. What remains (agreed scope)

- **Deferred projects:** books-on-server migration (kills localStorage book — audit gate 1), Postgres + migration history, DPDP program, httpOnly token storage.

- **Queued smaller items:** per-tenant write rate limits (needs Redis), pagination on remaining list endpoints, audit-trail diffs for bills/parties/items, tuned CSP, GSTR-3B 3.1(d) inward-RCM, standalone e-way bill.
- **Blocked on external input:** NIC sandbox credentials for a live IRP round-trip; CA validation of GSTR JSON before claiming "filing-ready".

Generated 19 Aug 2026 · Neev One · compares audit-report.md (Accio) against commits 59c2900 / aad4b97 / c9604da on main